

- 1、菜刀流量特征
- 2、蚁剑流量特征
- 3、哥斯拉流量特征
- 4、冰蝎1.0流量特征
- 5、冰蝎2.0流量特征
- 6、冰蝎3.0流量特征
- 7、冰蝎4.0流量特征
- 8、cs流量特征
- 9、MSF流量特征

最开始是明文传输，后来采用base64加密



- (1) 请求包中ua头为百度，火狐
- (2) 请求实体中存在eval，base64等特征字符
- (3) 请求实体中传递的payload为base64编码，(base64_decode(\$_POST[z0]))对payload进行解码，并且存在固定的参数z0为：

QGLuaV9zZXQolmRpc3BsYXlfZXJyb3JzIiwicMClpO0BzZXRfdGltZV9saW1pdCgwKTtpZihQSFBfVkvS
U0IPTjwnNS4zLjAnKXtAc2V0X21hZ2ljX3F1b3Rlc19ydW50aW1lKDApO307ZWNoBygiWEBZlik7J

注:

- (1) 有少数时候eval方法会被assert方法替代
- (2) \$_POST也会被\$_GET、\$_REQUEST替代
- (3) z0是菜刀默认的参数, 这个地方也有可能被修改为其他参数名

2、蚁剑流量特征

```
POST /shell.php?pass=one HTTP/1.1
Host: 192.168.41.162:80
Accept-Encoding: gzip, deflate
User-Agent: antSword/v2.1
Content-Type: application/x-www-form-urlencoded
Content-Length: 942
Connection: close

0x81bf9df175a97=QGLuaV9zZXQolmRpc3BsYXlfZXJyb3JzIiwicMClpO0BzZXRfdGltZV9saW1pdCgwKTtpZihQSFBfVkvS
vdXQ7fTtmdw5jdGlvbiBhc291dHB1dCgpeyRvdXRwdXQ9b2JfZ2V0X2NvbWVbRlbnRzKk7b2JfZW5kX2NsZWZuKk7ZWNoByA1NDUwM2EiO2VjaG8gQGZzZW5jKCR
vdXRwdXQpO2VjaG8gImJlYjgyIj9b2Jfc3RhcnoKTt0cn17JEQ9ZGlybmFtZSgkX1NFULZFUlsiu0NSSVBUX0ZJTEVOQU1FI0p02lmKCREPT0iIkkRD1kaXJ
uYWllKCRfU0VSvkvSWyJQVVRlX1RSQU5TEFEURUQXSk7JFI9InskRH0JiJtpZihzdWJzdHioJEQsMCwKSE9Ii8iKXtmb3JlYWNoKHJhbmdlKCJDIiwiwiPyXM
gJEwpawYoaXNfZGlyKCJ7JEx9oiIpKSRLj0ieyRMfToiO31lbHNleyRSLj0ielyI7fSRSLj0iCSI7JHU9KGZ1bmN0aw9uX2V4aXN0cygicG9zaXhfZ2V0ZWdpZCI
pKT9AcG9zaXhfZ2V0cHd1awQoQHbVc2L4X2dldGV1awQoSk6IiI7JHM9KCR1KT8kdVsibmFtZSJsdkBnZXRfY3VycmVudF9lc2VyKkck7JFIuPXBoCF91bmFtZSg
pOyRSLj0iCXskc30iO2VjaG8gJFI7O31jYXRjaChFeGNlcHRpb24gJGUpe2VjaG8gIkVSUk9S0i8vIi4kZS0%2BZ2V0TWVzc2FnZSgpO307YXNvdXRwdXQoKTtka
WUoKTS%3D&aaa=%40eval(%40base64_decode(%24_POST%5B_0x81bf9df175a97%5D))%3B HTTP/1.1 200 OK
Date: Wed, 16 Dec 2020 08:13:45 GMT
Server: Apache/2.4.23 (win32) OpenSSL/1.0.2j mod_fcgid/2.3.9
X-Powered-By: PHP/7.0.12
Connection: close
Transfer-Encoding: chunked
Content-Type: text/html; charset=UTF-8

4503ac:/Users/test/Desktop/www C: Windows NT WIN-10ET609J8JC 6.1 build 7601 (Windows Server 2008 R2 Datacenter Edition
Service Pack 1) i586 testbeb82
```

数据包流量特征:

- (1) 请求中的User-Agent值是: antSword/*, 也有可能是: Mozilla/5.0 (Windows NT)
AppleWebKit/ (KHTML, like Gecko) Chrome/* Safari/
- (2) 请求体存在 @ini_set("display_errors", "0");@set_time_limit(0); , 也会有eva的特征
- (3) 混淆加密后, 为参数名大多以“_0x.....=”这种形式 (下划线可替换为其他), 以及dirname、
get_current_user函数的字眼
- (4) 在命令执行时有目录标记[S]、[E]、[R]、[D]、等, 说明已经拿到shell了 (在执行系统命令)

payload特征:

- (1) php中使用assert, eval执行

(2) asp中使用eval

(3) 在jsp使用的是Java类加载 (ClassLoader), 同时会带有base64编码解码等字符特征

3、哥斯拉流量特征

第2个请求

#	Host	Method	URL	Params	Edited	Status	Length	MIME type	Extension	Title	Comment
86	http://just.for.test	POST	/php_xor_b64.php	✓		200	415	script	php		
85	http://just.for.test	POST	/php_xor_b64.php	✓		200	415	script	php		
84	http://just.for.test	POST	/php_xor_b64.php	✓		200	350	HTML	php		

Request

```
1 POST http://just.for.test/php_xor_b64.php HTTP/1.1
2 Cookie: PHPSESSID=r1ebjbkuhraqblb0vlla7sckf8;
3 User-Agent: Java/9.0.4
4 Host: just.for.test
5 Accept: text/html, image/gif, image/jpeg, *, q=.2, */*; q=.2
6 Content-type: application/x-www-form-urlencoded
7 Content-Length: 37
8 Connection: close
9
10 pass=WwFDCVsCLQBauTY2ZGRhRVMXQw%3D%3D
```

Response

```
1 HTTP/1.1 200 OK
2 Server: nginx/1.16.1
3 Date: Sat, 21 Aug 2021 07:03:03 GMT
4 Content-Type: text/html; charset=UTF-8
5 Connection: close
6 X-Powered-By: PHP/7.3.11
7 Set-Cookie: PHPSESSID=r1ebjbkuhraqblb0vlla7sckf8; path=/
8 Expires: Thu, 19 Nov 1981 08:52:00 GMT
9 Cache-Control: no-store, no-cache, must-revalidate
10 Pragma: no-cache
11 Content-Length: 64
12
13 d24e941e79e77b73Ke8/YTRmY2E3J//9YmQm70odNWE0Zg==8447ffd99cd17519
```

数据包流量特征:

(1) cookie字段, 最后一个Cookie的值出现; (尾值出现分号)

(2) 在默认的情况下, 如果不修改User-Agent, User-Agent会返回使用的jdk信息

(3) 响应包的结构特征为: md5前十六位+base64+md5后十六位

(4) 请求中的Accept头是:

Accept:text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,/;q=0.8

或者:

Accept:text/html, image/gif, image/jpeg, *, q=.2, /; q=.2

(5) 响应中的Cache-Control头是: Cache-Control: no-store, no-cache, must-revalidate

(6) 首次连接shell会有三次请求:

①: 发送一段固定代码 (payload), http响应为空

②: 发送一段固定代码 (test), 执行结果为固定内容

③: 发送一段固定代码 (getBacisInfo)

payload特征:

(1) jsp会出现xc、pass字符和Java反射 (ClassLoader, getClass().getClassLoader()) , base64加解码等特征

(2) php, asp则为普通的一句话木马

4、冰蝎1.0流量特征

冰蝎1有一个密钥协商过程, 这个过程是明文传输, 并且有两次流量, 用来校验

其次在POST返回包中相对正常流量多了 **Transfer-Encoding: chunked**, Transfer-Encoding主要是用来改变报文格式, 这里指的是利用分块进行传输。可以基于此特征值进行检测

当然, 也可以用更简单的方法进行检测, 比如url中包含 .php?pass=来进行检测

5、冰蝎2.0流量特征



```
GET /session.php?pass=183 HTTP/1.1
Content-type: application/x-www-form-urlencoded
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/5.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; InfoPath.3; .NET4.0C; .NET4.0E; SE 2.X MetaSr 1.0)
Host: 192.168.41.162
Accept: text/html, image/gif, image/jpeg, *, q=.2, */*; q=.2
Connection: keep-alive

HTTP/1.1 200 OK
Date: Thu, 17 Dec 2020 06:20:42 GMT
Server: Apache/2.4.23 (Win32) OpenSSL/1.0.2j mod_fcgid/2.3.9
X-Powered-By: PHP/7.0.12
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Set-Cookie: PHPSESSID=dr52k6n7rblkvuah7fh37t7e5; path=/
Keep-Alive: timeout=5, max=94
Connection: Keep-Alive
Transfer-Encoding: chunked
Content-Type: text/html; charset=UTF-8

...3704bf8c946e1b28GET /session.php?pass=230 HTTP/1.1
Content-type: application/x-www-form-urlencoded
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/5.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; InfoPath.3; .NET4.0C; .NET4.0E; SE 2.X MetaSr 1.0)
Host: 192.168.41.162
Accept: text/html, image/gif, image/jpeg, *, q=.2, */*; q=.2
Connection: keep-alive

HTTP/1.1 200 OK
Date: Thu, 17 Dec 2020 06:20:42 GMT
Server: Apache/2.4.23 (Win32) OpenSSL/1.0.2j mod_fcgid/2.3.9
X-Powered-By: PHP/7.0.12
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Set-Cookie: PHPSESSID=dna9peki4lhre32335q98urrj4; path=/
Keep-Alive: timeout=5, max=93
Connection: Keep-Alive
Transfer-Encoding: chunked
Content-Type: text/html; charset=UTF-8

...99030fc0bb93de17POST /session.php HTTP/1.1
Content-Type: application/x-www-form-urlencoded
Cookie: PHPSESSID=dna9peki4lhre32335q98urrj4; path=/
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/5.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0; InfoPath.3; .NET4.0C; .NET4.0E; SE 2.X MetaSr 1.0)
Cache-Control: no-cache
Pragma: no-cache
Host: 192.168.41.162
Accept: text/html, image/gif, image/jpeg, *, q=.2, */*; q=.2
Connection: keep-alive
Content-Length: 1112
```

由服务端随机生成的16位 AES Key 用于解密代码

数据包流量特征:

(1) 请求中的Accept头是: Accept: text/html,image/gif, image/jpeg, *, q=.2, */*; q=.2

(2) 内置了很多的UA头, 会出现某一个相同IP重复请求, 但是UA头不一样

(3) 密钥请求参数一般是2至3位随机纯数字

(4) 连接初期会返回16位密钥

(5) 所有请求 Cookie的格式都为： Cookie: PHPSESSID=; path=/;

6、冰蝎3.0流量特征

相比2.0少了动态密钥的获取的请求，AES 密钥变为连接密码32位md5的前16位，默认连接密码：reeyond

Request

Pretty Raw \n Actions ▾

```
1 POST /shell.php HTTP/1.1
2 Content-Type: text/html;charset=utf-8
3 User-Agent: Mozilla/5.0 (Windows; U; Windows NT 6.1; ) AppleWebKit/534.12 (KHTML, like Gecko)
  Maxthon/3.0 Safari/534.12
4 Cache-Control: no-cache
5 Pragma: no-cache
6 Host: 10.0.2.158
7 Accept: text/html, image/gif, image/jpeg, *, q=.2, */*; q=.2
8 Content-Length: 5484
9 Cookie: PHPSESSID=u37ml6co3chvd34oo4dtltb4h7;
10 Connection: close
11
12 3MnlyNMtoZViV5wotQHPJtwwj0F4b2lyToNK7LfdUnN7zmyQFfx/zaiGwUHg+8SlRr5QAWVdopiiVczjpFLjyU6RAwyoJGgtN55
  7dToKww0/7Pwfbbo3ZplI40L++SawBYFYdic+roW0b09rbonnTa52P57V80wUz1prlDUDt+THFdB5WpncCk+BiuxlboH7qqJnV
  E3JMr0DeNu7VXBx6iiHu2RrygSV59R9qIfF7kjJYzLv7Ubm4Bbif2pwZx0xaQu4wUflodDw4g6klKIyGvd1Y28S38chVY4FxrH3
  v7Cbi+CBUchBXvu9yyb8fAnfmdc0M2CQMB+Jc6+N426wp1VmN4M3SnXgdwF7YseNw0Jy7Zf4STFcxc05ADw3jV7s1cQHXSioL
  Y3Z7JeHezM7pBRCIPu4q18lAlje9iNBkZix1020Ys1Q9XjhXkLeMV00CmlPrAmOp2gqmG2xVgOMPVP4yR1a3wwnsYbc7pBRCgIf
  WC1Y7xM3KdTNOqVzeJVXPDV16r95HWstLa0EFY+lXm1viVYkT57I/wnmzrjB5bMUFz2hXLwzDIuCVZ/r2qfctp8YLS0AKalN+u/
  4tDLt8JNBcSjuM/i9k+H1xAxoiT9nohSL9aCqYvb4DUyFDo/qrcrutfQ11GGprJkIvDteXXpahgjwai/Zi03Lw7mz/hgr2xgMrK
  U6FiVjDbbebKdfCfRNjcNzy651HvLDaBbGgu7x4ZqCFLK3NM1hgU0/fmaUyL0b1jxUsLN0+gxqveShD1pZSf7KkkX15HJjmUKHc
  e5UfBeZeU1AYvTf202LF3cUVdycJR7qWSlaPgAI/IthJihJY3CpeXkXjt/ty4g6H9FkLKq7iIgZNgYG0Cxx6bx+k0LbVpS8TGh5
  8CpnrxFI8jZKF0q1gpDr32CUs1kAMeeJZ9YQYMKKTRCslamqu2Bn3gIogyef3LR4vt3s38+XtcsS5efLcH7EeuVaWhl1PWTlKZ
  XgG8kwyWi9wuqcEW1NGK+KlufWCraQOGnME1S1mqN/i+/Wet3UEiJ+VwLm0trraDGTwQApAzqdMncuF5VVMQxHrDa4Qt7eP9pZ0
  c3oWaKH7W7qu5lDD15PvEayfirmIK5SRCqnJLrhIsTtmki7WEqw06mrHNM02n8i5+sK04zOMIJLm4YYW8CjnTqU9/vUQ2bWX3Ng
```

0 matches

数据包流量特征：

(1) jsp的content-type为application/octet-stream

(2) 如果用户默认不提供UA头，则从系统中以下中随机选择一个UA头：

```
1 Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/535.1 (KHTML, like Gecko)
  Chrome/14.0.835.163 Safari/535.1
2 Mozilla/5.0 (Windows NT 6.1; WOW64; rv:6.0) Gecko/20100101 Firefox/6.0
3 Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/534.50 (KHTML, like Gecko)
  Version/5.1 Safari/534.50
4 Opera/9.80 (Windows NT 6.1; U; zh-cn) Presto/2.9.168 Version/11.50
5 Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Win64; x64; Trident/5.0;
  .NET CLR 2.0.50727; SLCC2; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0;
  InfoPath.3; .NET4.0C; Tablet PC 2.0; .NET4.0E)
6 Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1; WOW64; Trident/4.0; SLCC2;
  .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0;
  .NET4.0C; InfoPath.3)
7 Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0; GTB7.0)
8 Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 5.1)
9 Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; SV1)
10 Mozilla/5.0 (Windows; U; Windows NT 6.1; ) AppleWebKit/534.12 (KHTML, like Gecko)
  Maxthon/3.0 Safari/534.12
11 Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/5.0; SLCC2;
  .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0;
  InfoPath.3; .NET4.0C; .NET4.0E)
12 Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/5.0; SLCC2;
  .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0;
  InfoPath.3; .NET4.0C; .NET4.0E; SE 2.X MetaSr 1.0)
13 Mozilla/5.0 (Windows; U; Windows NT 6.1; en-US) AppleWebKit/534.3 (KHTML, like Gecko)
  Chrome/6.0.472.33 Safari/534.3 SE 2.X MetaSr 1.0
14 Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; WOW64; Trident/5.0; SLCC2;
  .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0;
  InfoPath.3; .NET4.0C; .NET4.0E)
15 Mozilla/5.0 (Windows NT 6.1) AppleWebKit/535.1 (KHTML, like Gecko) Chrome/13.0.782.41
  Safari/535.1 QQBrowser/6.9.11079.201
16 Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/5.0; SLCC2;
  .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729; Media Center PC 6.0;
  InfoPath.3; .NET4.0C; .NET4.0E) QQBrowser/6.9.11079.201
17 Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; WOW64; Trident/5.0)
```

(3) content-length为5464或5484比较多

(4) header默认为:

```

1 Accept: text/html, image/gif, image/jpeg, */*; q=.2, */*; q=.2
2 Cache-Control: no-cache
3 Pragma: no-cache
4 User-Agent: java/1.8

```

7、冰蝎4.0流量特征

冰蝎4.0可以不用连接密码，自定义传输协议的算法就是连接密码。

Request

Pretty Raw \n Actions ▼

```

1 POST /shell.php HTTP/1.1
2 Host: 127.0.0.1
3 Accept: application/json, text/javascript, */*; q=0.01
4 Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7
5 Content-type: application/x-www-form-urlencoded
6 Referer: http://127.0.0.1/0TF.php
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/96.0.4664.110 Safari/537.36
8 Content-Length: 2944
9 Connection: close
10 Accept-Encoding: gzip, deflate
11
12 dFAXQVlLORcHRQtLRlwMAhwFTAg/MvAQDFYQUF1bQghVXAsbFloJCxZQcK0b0GgeOT9sFOBcFRAOQUQEElQQF1VMTRoJNGxsRkc
  BSkdZFj4WRhFSRkwVRz8VVRlQVBEEAgE6V1xaCQEHHUZKR1YBAEdGRxoJNGxFQhVEHUBQERBYQT4RX0oBRz8VVRlQVBEEAgE6V1
  xaCQEHHUBaXVsWAFpBTag/MOZFQhUkSldGEQxbWzPARlgUEUocXxkSGk2AvKiAlLnc6vMRUBdKW1oMioi5jLKN30PoAVoKV1dWF
  oGNvoCjvN790YS7wVtTVgkCRloQXVbW2umHpereiZgFAEBHAEBHVRKD9ZWCiqfd7NLRuvNQXVYNDAC4bjQ4FUJFFAGW10ZAwsB
  Rx1JRh0IFltb0lZcWgkBBx1AS1dGFw1AHEwIPzMbaGg/AkxcVhYMW1tFd1xaFBwSQUwdVlQWBB0/HjkSGUZFRl4BQA8XB1EBUFY
  BC18DB1dRXQsHV0BeFD9sVV1LTkELCFQCF1xeFkBHCvZcEUIBAOEFEAkRC04fHEVIOBlGRUI8QF1TQQM+EFw4Ew8ZQgEDQQViFl

```

数据包流量特征：

(1) Accept 头通常是固定

```

1 Accept: application/json, text/javascript, */*; q=0.01
2 Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7

```

(2) 本地端口在 49700 左右，每连接一次，每建立一次新的连接，端口就依次增加

(3) content-type:一般为Application/x-www-form-urlencoded

(4) 内置10个UA头，每次连接shell时会随机选择一个进行使用

```
1 Mozilla/5.0 (Macintosh; Intel Mac OS X 11_2_3) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/89.0.4389.114 Safari/537.36
2 Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:87.0) Gecko/20100101 Fire
  fox/87.0"
3 Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/96.0.4664.110 Safari/537.36
4 Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/99.0.4844.74 Safari/537.36 Edg/99.0.1150.55
5 Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Geck
  o) Chrome/96.0.4664.110 Safari/537.36
6 Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:98.0) Gecko/20100101 Firefox/
  98.0
7 Mozilla/5.0 (Windows NT 10.0) AppleWebKit/537.36 (KHTML, like Gecko) Chrom
  e/84.0.4147.125 Safari/537.36
8 Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_6) AppleWebKit/537.36 (KHTM
  L, like Gecko) Chrome/84.0.4147.125 Safari/537.36
9 Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:79.0) Gecko/20100101 Fire
  fox/79.0
10 Mozilla/5.0 (Windows NT 6.3; Trident/7.0; rv:11.0) like Gecko
```

(5) 有固定的请求头和响应头，请求字节头：dFAXQV1LORcHRQtLRIwMAhwFTAg/M

8、cs流量特征

- (1) 基础特征：心跳包
- (2) 请求特征：下发的指令，url路径，老版本固定的ua头
- (3) 源码特征：checksum8 (92L 93L)

9、MSF流量特征

- (1) 端口号：msf默认使用4444端口作为反向连接端口
- (2) 数据内容：msf数据包通常包含特定字符串("meterpreter"、"revshell"等)

参考文献：

<https://xz.aliyun.com/t/9404>

<https://www.anquancclub.cn/27087.html>

